

CL2003

Fundamentos de ciberseguridad (GS)

UNIDAD DIDÁCTICA 1

Amenazas, vulnerabilidades y ataques informáticos

Contenidos explicados · Curso 2026/27

Módulo	CL2003 – Fundamentos de ciberseguridad (GS)
Duración del módulo	54 horas · 2.º curso
Resultado de aprendizaje principal	RA1 – Identifica las principales amenazas y vulnerabilidades en sistemas, redes y aplicaciones informáticas, relacionándolas con sus posibles consecuencias.
Temporalización propuesta UD1	9 horas (orientativa)

Material didáctico elaborado a partir del currículo CL2003 y de la matriz de RA–CE–indicadores del módulo.

1. Presentación de la unidad

La ciberseguridad comienza por comprender qué puede salir mal. Antes de configurar un cortafuegos, desplegar un IDS o responder a un incidente, es necesario distinguir correctamente los activos que se quieren proteger, las amenazas que pueden afectarles, las vulnerabilidades que facilitan un ataque y las consecuencias que este puede provocar.

Esta unidad desarrolla el primer Resultado de Aprendizaje del módulo. Su finalidad es que el alumnado adquiera un vocabulario técnico preciso, aprenda a clasificar amenazas y vulnerabilidades y sea capaz de relacionarlas mediante cadenas de ataque sencillas. La unidad incorpora también contenidos actuales de uso profesional, claramente diferenciados de los contenidos curriculares oficiales.

Idea central. Una amenaza no equivale a una vulnerabilidad. La amenaza es aquello que puede causar daño; la vulnerabilidad es una debilidad; el ataque es la acción que intenta aprovecharla; y el riesgo expresa la combinación entre probabilidad e impacto.

Resultado de aprendizaje y criterios de evaluación

RA1. Identifica las principales amenazas y vulnerabilidades en sistemas, redes y aplicaciones informáticas, relacionándolas con sus posibles consecuencias.

CE	Criterio de evaluación
CE1-a	Se han descrito las características y funciones de las principales amenazas informáticas, como malware, phishing, ransomware y ataques de denegación de servicio, entre otros.
CE1-b	Se han clasificado las vulnerabilidades más comunes en sistemas operativos, redes y aplicaciones, justificando su impacto potencial en la seguridad.
CE1-c	Se han relacionado las amenazas identificadas con las vulnerabilidades que explotan, explicando los mecanismos utilizados por los atacantes.
CE1-d	Se han evaluado las consecuencias de las amenazas de seguridad sobre la confidencialidad, integridad y disponibilidad de los datos y servicios en casos específicos.
CE1-e	Se han distinguido entre las diferentes categorías de ataques (internos, externos, dirigidos, masivos) según el contexto y los objetivos del atacante.
CE1-f	Se han identificado las señales y síntomas que podrían indicar la presencia de amenazas o vulnerabilidades activas en un sistema o red.

Índice de contenidos

Código	Contenido	Tipo
1.1	Amenaza, vulnerabilidad, riesgo y ataque	Curricular
1.2	Confidencialidad, integridad y disponibilidad (CIA)	Curricular
1.3	Amenazas activas y pasivas	Curricular
1.4	Malware	Curricular
1.5	Ingeniería social	Curricular
1.6	DoS/DDoS y Man-in-the-Middle	Curricular
1.7	Vulnerabilidades en sistemas, aplicaciones y redes	Curricular

Código	Contenido	Tipo
1.8	Seguridad y vulnerabilidades Wi-Fi	Curricular
1.9	Exploits y herramientas automatizadas	Curricular
1.10	SQL Injection y XSS	Curricular
1.11	Relación amenaza–vulnerabilidad–explotación	Curricular
1.12	Impacto sobre sistemas, datos y servicios	Curricular
1.13	Señales y síntomas de actividad maliciosa	Curricular
1.14	Clasificación de ataques	Curricular
1.A	MITRE ATT&CK y TTP	Actual
1.B	CVE, CVSS y priorización	Actual
1.C	OWASP Top 10:2025	Actual
1.D	RaaS, info stealers, credential stuffing, MFA fatigue y supply chain	Actual
1.E	OSINT y superficie de ataque	Actual
1.F	Seguridad de APIs	Actual
1.G	Dependencias, SBOM y cadena de suministro	Actual
1.H	IA ofensiva y defensiva	Actual

1.1 Conceptos de amenaza, vulnerabilidad, riesgo y ataque [Contenido curricular]

En seguridad informática se utilizan varios términos relacionados que no deben confundirse. Una correcta identificación de cada concepto permite analizar un problema de forma ordenada y seleccionar controles proporcionados.

Concepto	Definición operativa
Activo	Recurso que posee valor para una organización y que debe protegerse: información, servidores, cuentas, aplicaciones, servicios, equipos, reputación o procesos.
Amenaza	Circunstancia, actor o evento con capacidad potencial de producir un daño. Puede ser intencionada (atacante), accidental (error humano) o ambiental/técnica.
Vulnerabilidad	Debilidad en un activo, proceso, configuración o control que puede ser aprovechada por una amenaza.
Ataque	Acción deliberada destinada a comprometer un activo, normalmente aprovechando una vulnerabilidad o abusando de una funcionalidad legítima.
Riesgo	Posibilidad de que una amenaza explote una vulnerabilidad y cause un impacto. En un análisis sencillo se valora combinando probabilidad e impacto.
Control o salvaguarda	Medida preventiva, detectiva, correctiva o compensatoria utilizada para reducir la probabilidad o el impacto de un riesgo.

Ejemplo: una aplicación web es un activo. Tener una versión sin soporte con una vulnerabilidad conocida constituye una debilidad. Un atacante externo es una amenaza. Si intenta aprovechar esa debilidad para ejecutar acciones no autorizadas, está realizando un ataque. El riesgo dependerá de la probabilidad de éxito y del daño potencial.

Regla de análisis. No se debe valorar una vulnerabilidad únicamente por su existencia. Hay que considerar si el activo está expuesto, si existe una vía realista de explotación, qué privilegios se requieren y qué impacto tendría la explotación.

1.2 Principios de confidencialidad, integridad y disponibilidad (CIA) [Contenido curricular]

La tríada CIA constituye uno de los modelos más utilizados para explicar los objetivos básicos de la seguridad de la información. Un incidente puede afectar a uno, dos o a los tres principios simultáneamente.

Principio	Qué protege	Ejemplo de pérdida
Confidencialidad	La información solo es accesible por personas, sistemas o procesos autorizados.	Filtración de expedientes, robo de credenciales, exposición de una base de datos.
Integridad	La información y los sistemas se mantienen correctos, completos y sin alteraciones no autorizadas.	Modificación de calificaciones, manipulación de registros, alteración de un ejecutable.
Disponibilidad	La información y los servicios están accesibles cuando los usuarios autorizados los necesitan.	Caída de un servidor, ransomware que cifra sistemas, DDoS contra un servicio web.

En entornos profesionales suele añadirse la autenticidad —poder verificar que una identidad, sistema o mensaje es quien dice ser— y la trazabilidad o responsabilidad —poder reconstruir quién hizo qué y cuándo—. Aunque estos conceptos son importantes, el currículo de esta unidad centra la evaluación del impacto en la tríada CIA.

1.3 Amenazas activas y pasivas y evaluación de su impacto [Contenido curricular]

Una clasificación clásica diferencia entre amenazas pasivas y activas según exista o no modificación del sistema o de la información.

Tipo	Descripción	Ejemplos	Impacto habitual
Pasiva	Busca obtener información sin alterar de forma evidente el sistema.	Intercepción de comunicaciones, escucha de tráfico, recopilación de información expuesta.	Principalmente confidencialidad.
Activa	Modifica, interrumpe, destruye o utiliza recursos de forma no autorizada.	Ransomware, modificación de datos, suplantación, DDoS.	Integridad y/o disponibilidad; también confidencialidad.

La clasificación no siempre es excluyente. Una campaña puede comenzar de forma pasiva, con reconocimiento y observación, y pasar después a acciones activas. En consecuencia, la evaluación debe contemplar el ciclo completo y no limitarse a una única técnica.

1.4 Malware: virus, gusanos, troyanos, spyware, ransomware y otras amenazas [Contenido curricular]

Malware es un término general para el software diseñado o utilizado con fines maliciosos. La clasificación puede hacerse por forma de propagación, por objetivo, por persistencia o por comportamiento. Un mismo malware puede combinar varias funciones.

Tipo	Cómo funciona	Riesgo principal
Virus	Se inserta en otros archivos o programas y suele requerir ejecución para propagarse.	Alteración o destrucción de información; propagación local.
Gusano	Se propaga de forma autónoma, normalmente a través de redes o servicios vulnerables.	Expansión rápida, consumo de recursos, distribución de otras cargas.
Troyano	Se presenta como software legítimo o útil para lograr que el usuario lo ejecute.	Acceso inicial, descarga de malware adicional, robo de información.
Spyware / infostealer	Recopila información del equipo o del usuario.	Robo de credenciales, cookies, tokens, datos personales y financieros.
Ransomware	Bloquea o cifra información y exige un pago; con frecuencia combina cifrado con robo previo de datos.	Interrupción operativa, pérdida de datos, extorsión y filtraciones.
Rootkit	Busca ocultar procesos, ficheros o actividad y mantener privilegios elevados.	Persistencia y evasión de controles.
Bot / botnet	Convierte el equipo en un nodo controlado remotamente.	DDoS, spam, fraude, proxy, distribución de malware.
Wiper	Su objetivo principal es destruir o inutilizar información o sistemas.	Pérdida de integridad y disponibilidad.

Vectores de entrada habituales

- Adjuntos o enlaces maliciosos en correo y mensajería.
- Descargas desde sitios comprometidos o software modificado.
- Explotación de servicios o aplicaciones vulnerables expuestos a Internet.
- Credenciales robadas que permiten el acceso remoto legítimo y posterior despliegue de malware.
- Dependencias, actualizaciones o componentes de terceros comprometidos.
- Dispositivos extraíbles y movimiento lateral desde otros equipos comprometidos.

Punto de evaluación. Para reconocer una amenaza no basta con memorizar su nombre. Debe explicarse qué objetivo persigue, cómo entra o se propaga, qué activo afecta y qué medidas reducen el riesgo.

1.5 Ingeniería social: phishing y otras técnicas de manipulación

[Contenido curricular]

La ingeniería social explota factores humanos —confianza, urgencia, miedo, autoridad, curiosidad o deseo de ayudar— para inducir a una persona a revelar información o realizar una acción que favorece al atacante. No exige necesariamente una vulnerabilidad técnica.

Técnica	Descripción
Phishing	Mensaje masivo que imita a una entidad legítima para obtener credenciales, datos o provocar una descarga.
Spear phishing	Phishing dirigido y personalizado hacia una persona, equipo o función concreta.
BEC / fraude del CEO	Suplantación de directivos o proveedores para provocar pagos o cambios de datos bancarios.
Smishing	Phishing mediante SMS o servicios de mensajería.
Vishing	Engaño mediante llamadas de voz o sistemas de telefonía.
Quishing	Uso de códigos QR para dirigir a la víctima a recursos fraudulentos.
Pretexting	Construcción de una historia o identidad falsa para obtener información o acceso.
Baiting	Uso de un incentivo o señuelo para provocar una acción insegura.

Señales de alerta

- Urgencia artificial: “actúa ahora”, “tu cuenta será bloqueada”.
- Solicitud de secretos que una entidad legítima no debería pedir: contraseña completa, código MFA, token de recuperación.
- Dominio, remitente o URL que no coincide con la organización real.
- Cambio inesperado de cuenta bancaria o procedimiento habitual.
- Documento o enlace no solicitado que exige habilitar contenido, iniciar sesión o descargar software.
- Inconsistencias de lenguaje, contexto, identidad o canal de comunicación.

La respuesta correcta combina formación, procedimientos de verificación por canal alternativo, autenticación fuerte, filtrado y mecanismos técnicos de detección. La formación aislada no elimina el riesgo si los procesos permiten ejecutar operaciones sensibles sin validaciones adicionales.

1.6 Ataques de red: DoS, DDoS y Man-in-the-Middle [Contenido curricular]

Denegación de servicio: DoS y DDoS

Un ataque de denegación de servicio busca degradar o impedir el acceso legítimo a un recurso. Puede agotar ancho de banda, conexiones, memoria, CPU o capacidad de una aplicación. En un DDoS, la carga procede de múltiples sistemas distribuidos, lo que dificulta el filtrado y aumenta la capacidad del ataque.

Modalidad	Objetivo	Impacto
Volumétrico	Satura la capacidad de comunicaciones.	Disponibilidad.
Protocolo/estado	Agota tablas de conexión o recursos de equipos de red.	Disponibilidad de infraestructura.
Capa de aplicación	Genera solicitudes costosas o abusivas contra una función concreta.	Disponibilidad del servicio y recursos de backend.

Man-in-the-Middle (MitM)

En un escenario Man-in-the-Middle, el atacante consigue situarse lógicamente entre dos extremos de una comunicación para observar, redirigir o manipular el tráfico. El riesgo aumenta cuando no existe cifrado, cuando no se valida correctamente la identidad del servidor o cuando el usuario acepta certificados o redes no confiables.

Medidas habituales: TLS correctamente configurado, validación de certificados, redes inalámbricas seguras, VPN en escenarios apropiados, protección de DNS, segmentación y mecanismos de detección de anomalías.

1.7 Vulnerabilidades en sistemas operativos, aplicaciones y redes

[Contenido curricular]

Una vulnerabilidad puede proceder de un error de programación, una configuración incorrecta, un diseño inseguro, credenciales débiles, permisos excesivos, un componente desactualizado o un proceso deficiente. La clasificación debe ayudar a decidir la respuesta, no limitarse a poner una etiqueta.

Ámbito	Ejemplos de debilidades
Sistema operativo	Versiones sin soporte, servicios innecesarios, permisos incorrectos, elevación de privilegios, credenciales por defecto.
Aplicación	Validación insuficiente, fallos de autenticación/autorización, manejo inseguro de entradas, exposición de información, errores de lógica.
Red	Servicios expuestos, reglas permisivas, protocolos inseguros, segmentación deficiente, dispositivos sin actualizar.
Configuración	Interfaces administrativas públicas, directorios listables, depuración activada, claves embebidas, permisos excesivos.
Dependencias	Bibliotecas vulnerables, paquetes abandonados, versiones no fijadas, repositorios o cuentas de mantenedores comprometidas.

Prioridad. “Crítica” no significa automáticamente “urgente en todos los entornos”. Una vulnerabilidad expuesta a Internet en un sistema esencial puede exigir una reacción inmediata; la misma vulnerabilidad en un componente no ejecutable o aislado puede tener menor prioridad operativa.

1.8 Vulnerabilidades en redes inalámbricas y cifrados obsoletos

[Contenido curricular]

Las redes inalámbricas comparten el medio de transmisión y, por tanto, requieren especial atención a la autenticación, el cifrado y la configuración. Una señal radioeléctrica puede ser recibida fuera del espacio físico de una organización.

Elemento	Riesgo o consideración
Red abierta	No cifra el enlace Wi-Fi. El tráfico que además carezca de cifrado de aplicación queda especialmente expuesto.
WEP	Tecnología obsoleta y no adecuada para proteger redes actuales.
WPA/WPA2 con TKIP	Configuraciones antiguas que deben evitarse cuando exista soporte para mecanismos modernos.
WPA2-AES	Sigue siendo frecuente, pero la robustez depende también de la contraseña, configuración y gestión de claves.
WPA3	Mejora mecanismos de autenticación y protección; requiere configuración y compatibilidad adecuadas.
WPS	Puede ampliar la superficie de ataque y normalmente debe deshabilitarse cuando no sea necesario.
Evil twin / AP falso	Punto de acceso que imita una red legítima para inducir a los usuarios a conectarse.

La protección moderna combina cifrado adecuado, contraseñas o autenticación empresarial robustas, segmentación de invitados, actualización del firmware, desactivación de funciones innecesarias y supervisión de puntos de acceso no autorizados.

1.9 Exploits y herramientas automatizadas de explotación [Contenido curricular]

Un exploit es código, una secuencia de acciones o una técnica que aprovecha una vulnerabilidad para provocar un comportamiento no previsto. No toda vulnerabilidad dispone de un exploit público, y la existencia de un exploit no implica que vaya a funcionar en cualquier sistema.

Concepto	Significado
PoC (proof of concept)	Demostración de que una vulnerabilidad es explotable; puede ser incompleta o limitada.
Exploit funcional	Implementación capaz de aprovechar la vulnerabilidad bajo determinadas condiciones.
Zero-day	Vulnerabilidad que se explota antes de que exista una corrección disponible o antes de que el riesgo sea ampliamente conocido.
Escáner de vulnerabilidades	Herramienta que identifica configuraciones o versiones potencialmente vulnerables; no equivale necesariamente a explotación.
Framework de pruebas	Conjunto de herramientas que facilita pruebas controladas de seguridad en entornos autorizados.

Uso ético y legal. Las herramientas de explotación solo deben utilizarse sobre sistemas propios o con

autorización expresa y alcance definido. En el aula se emplearán únicamente laboratorios controlados, máquinas vulnerables diseñadas para aprendizaje o simulaciones no dañinas.

1.10 Ataques a aplicaciones web: inyección SQL y Cross-Site Scripting (XSS) [Contenido curricular]

Inyección SQL

La inyección SQL aparece cuando una aplicación mezcla datos introducidos por el usuario con instrucciones SQL sin separar correctamente código y datos. El problema no es “SQL” en sí, sino la construcción insegura de consultas y la ausencia de controles adecuados.

Ejemplo conceptual de construcción insegura

```
consulta = "SELECT * FROM usuarios WHERE nombre = '" + entrada + "'"
// La entrada del usuario se incorpora como parte de la instrucción SQL.
```

Enfoque correcto

```
consulta = "SELECT * FROM usuarios WHERE nombre = ?"
ejecutar_consulta_preparada(consulta, entrada)
// La entrada se transmite como dato, no como código SQL.
```

Controles principales: consultas parametrizadas, privilegios mínimos en la cuenta de base de datos, validación de entradas, tratamiento seguro de errores, revisión de código y pruebas de seguridad.

Cross-Site Scripting (XSS)

XSS permite que contenido controlado por un atacante sea interpretado por el navegador como código activo dentro del contexto de una aplicación legítima. Puede ser reflejado, almacenado o basado en el DOM, según cómo llegue y se procese el contenido.

Patrón inseguro en el navegador

```
elemento.innerHTML = entradaUsuario; // interpreta contenido como HTML
```

Alternativa segura para texto

```
elemento.textContent = entradaUsuario; // trata la entrada como texto
```

Controles principales: codificación de salida según contexto, plantillas con autoescape, evitar APIs peligrosas, validación complementaria, Content Security Policy (CSP) y revisión del flujo de datos desde la entrada hasta la salida.

1.11 Relación entre amenazas, vulnerabilidades y mecanismos de explotación [Contenido curricular]

El análisis de seguridad resulta más útil cuando se representa como una cadena causal. Una amenaza necesita una vía para alcanzar el activo. Esa vía suele depender de una superficie de ataque y de una vulnerabilidad o abuso de funcionalidad. El mecanismo de explotación permite materializar el ataque y provocar consecuencias.

Etapas	Ejemplo
1. Activo	Servidor web con datos de clientes.
2. Amenaza	Atacante externo con motivación económica.

Etapa	Ejemplo
3. Superficie	Aplicación pública accesible desde Internet.
4. Vulnerabilidad	Componente desactualizado o validación de entrada deficiente.
5. Mecanismo	Explotación de la debilidad o abuso de credenciales.
6. Acción	Acceso, ejecución, movimiento o extracción de información.
7. Impacto	Pérdida de confidencialidad, integridad y/o disponibilidad.
8. Controles	Parcheado, autenticación fuerte, filtrado, mínimo privilegio, monitorización y copias de seguridad.

Esta forma de razonar evita confundir el nombre de una amenaza con la causa real del incidente y facilita elegir controles en varios puntos de la cadena.

1.12 Evaluación del impacto de los ataques sobre sistemas, datos y servicios [Contenido curricular]

El impacto describe las consecuencias si una amenaza llega a materializarse. Debe valorarse desde varias perspectivas: técnica, operativa, económica, legal y reputacional.

Dimensión	Ejemplos
Técnico	Pérdida o alteración de datos, caída de sistemas, cuentas comprometidas, malware persistente.
Operativo	Paralización de procesos, pérdida de productividad, indisponibilidad de servicios, necesidad de reconstrucción.
Económico	Costes de respuesta, recuperación, pérdida de ingresos, contratación externa, sanciones o fraude.
Legal/compliance	Incumplimientos regulatorios, notificaciones de brecha, obligaciones contractuales.
Reputacional	Pérdida de confianza de clientes, proveedores o usuarios; impacto público del incidente.

Para priorizar puede utilizarse una matriz sencilla probabilidad × impacto, pero debe evitarse una falsa precisión matemática. La valoración debe justificarse mediante evidencias: criticidad del activo, exposición, facilidad de explotación, controles existentes y consecuencias reales y para el negocio.

1.13 Señales y síntomas de actividad maliciosa en sistemas y redes [Contenido curricular]

La detección parte de cambios observables. Una señal aislada rara vez demuestra por sí sola un ataque; el objetivo es correlacionar evidencias y distinguir comportamientos normales de anomalías relevantes.

Fuente	Ejemplos de señales
Sistema/endpoint	Procesos desconocidos, consumo inusual de CPU o disco, tareas programadas nuevas, servicios inesperados, desactivación de controles.
Autenticación	Muchos fallos de inicio de sesión, accesos desde ubicaciones inusuales, altas de usuarios inesperadas, cambios de privilegios.
Red	Conexiones a destinos atípicos, picos de tráfico, escaneos, comunicaciones periódicas no explicadas, resolución DNS anómala.

Fuente	Ejemplos de señales
Aplicación web	Errores repetidos, peticiones anómalas, picos en endpoints concretos, patrones de entradas inválidas o abuso de autenticación.
Correo	Reglas de reenvío no autorizadas, accesos extraños, mensajes enviados sin conocimiento del usuario.
Datos	Accesos masivos, descargas no habituales, cambios inesperados, cifrado o borrado repentino de grandes volúmenes.

Falsos positivos y contexto

Una alerta puede ser legítima: una copia de seguridad genera tráfico masivo, un administrador ejecuta una herramienta de inventario o un proceso de mantenimiento modifica muchos archivos. Por eso se deben revisar el contexto, el horario, la identidad, el activo y el comportamiento histórico antes de concluir que existe un incidente.

1.14 Clasificación de ataques según origen, alcance y objetivo

[Contenido curricular]

Categoría	Criterio	Ejemplo
Interno	El origen se encuentra dentro de la organización o utiliza privilegios internos. Puede ser malicioso o derivar de abuso/negligencia.	Usuario que extrae información fuera de sus funciones.
Externo	El actor se encuentra fuera de la organización y busca acceder a recursos expuestos o engañar a usuarios.	Campaña de phishing o ataque contra un servicio público.
Dirigido	El atacante selecciona una organización, persona o activo concreto y adapta la campaña.	Spear phishing contra administradores.
Masivo	El ataque se distribuye a gran escala sin una selección muy específica de víctimas.	Campaña automatizada contra muchos servicios vulnerables.

Las categorías pueden solaparse. Un atacante externo puede realizar un ataque dirigido; un usuario interno puede colaborar con un actor externo; una campaña masiva puede terminar enfocándose en las víctimas que responden. Lo importante es justificar la clasificación con el contexto y los objetivos observados.

2. Ampliaciones actuales de industria

Los siguientes apartados amplían el contenido curricular con marcos, tecnologías y riesgos utilizados actualmente en entornos profesionales. No sustituyen los contenidos oficiales: los conectan con herramientas y prácticas de la industria.

1.A Modelado de amenazas mediante MITRE ATT&CK y TTP [Ampliación actual]

MITRE ATT&CK es una base de conocimiento que organiza comportamientos observados de adversarios. Su utilidad didáctica reside en separar el objetivo táctico del atacante de la técnica concreta utilizada para alcanzarlo.

En ATT&CK, una táctica responde al “por qué” de una acción del adversario y una técnica describe “cómo” intenta lograr ese objetivo. Los procedimientos describen implementaciones observadas en campañas o actores concretos. De ahí la expresión TTP: tácticas, técnicas y procedimientos.

A septiembre de 2026, la versión vigente de ATT&CK es la 19.2. La matriz Enterprise trabaja con 15 tácticas. En 2026 MITRE dividió la antigua Defense Evasion en dos tácticas diferenciadas: Stealth y Defense Impairment, lo que refuerza la distinción entre ocultar actividad y degradar los mecanismos defensivos.

Táctica ATT&CK Enterprise	Finalidad resumida
Reconnaissance	Obtener información para preparar operaciones.
Resource Development	Preparar infraestructura, cuentas o recursos.
Initial Access	Conseguir acceso inicial.
Execution	Ejecutar código o acciones.
Persistence	Mantener acceso.
Privilege Escalation	Obtener permisos superiores.
Stealth	Ocultar o camuflar actividad.
Defense Impairment	Deteriorar mecanismos y herramientas defensivas.
Credential Access	Obtener credenciales.
Discovery	Conocer el entorno comprometido.
Lateral Movement	Moverse entre sistemas.
Collection	Reunir información de interés.
Command and Control	Comunicarse con sistemas comprometidos.
Exfiltration	Extraer datos.
Impact	Manipular, interrumpir o destruir sistemas y datos.

Uso en clase. ATT&CK no es una lista de “herramientas de hacking”. Se utiliza para describir comportamientos, analizar cadenas de ataque, relacionar evidencias y diseñar detecciones y mitigaciones.

1.B Gestión de vulnerabilidades mediante CVE, CVSS y priorización basada en riesgo [Ampliación actual]

La gestión profesional de vulnerabilidades necesita identificadores comunes y criterios de priorización. CVE proporciona identificadores públicos para vulnerabilidades conocidas. CVSS aporta un lenguaje estandarizado para comunicar su gravedad técnica, pero la decisión de tratamiento debe incorporar el contexto del activo.

CVSS 4.0 es la versión vigente del estándar de FIRST. Organiza la evaluación en grupos de métricas Base, Threat, Environmental y Supplemental. El resultado numérico ayuda a comparar severidad, pero no representa por sí solo la probabilidad real de explotación ni la criticidad de un activo concreto.

Elemento	Utilidad
CVE	Identificador común de una vulnerabilidad publicada. Facilita correlacionar avisos, productos y herramientas.

Elemento	Utilidad
CWE	Clasificación de tipos de debilidad de software; describe patrones de errores, no una vulnerabilidad concreta.
CVSS	Sistema de puntuación de características y severidad técnica.
Contexto	Exposición del activo, criticidad, controles, existencia de explotación, impacto para la organización.
Prioridad	Decisión operativa sobre qué corregir primero; combina gravedad técnica y riesgo real.

Ejemplo: una vulnerabilidad con puntuación alta en una aplicación aislada y no utilizada puede requerir menos urgencia que una vulnerabilidad de puntuación moderada explotada activamente en un servicio público crítico. La priorización basada en riesgo evita tratar todas las vulnerabilidades como equivalentes.

1.C OWASP Top 10:2025 [Ampliación actual]

OWASP Top 10 es un documento de concienciación para seguridad de aplicaciones web. La edición 2025 actualiza las categorías y da mayor relevancia a configuración, cadena de suministro, integridad y observabilidad.

Código 2025	Categoría
A01	Pérdida de control de acceso
A02	Configuración de seguridad incorrecta
A03	Fallas en la cadena de suministro de software
A04	Fallas criptográficas
A05	Inyección
A06	Diseño inseguro
A07	Fallas de autenticación
A08	Fallas en la integridad del software o de los datos
A09	Fallas en el registro, alerta y monitoreo de seguridad
A10	Manejo inadecuado de condiciones excepcionales

La UD1 se conecta especialmente con A01, A02, A03, A05 y A07: control de acceso, configuraciones inseguras, cadena de suministro, inyección y autenticación. Estos riesgos muestran que una aplicación puede ser vulnerable aunque el sistema operativo esté actualizado: el diseño, la lógica y las dependencias también forman parte de la superficie de ataque.

1.D Ataques actuales: RaaS, infostealers, credential stuffing, MFA fatigue y cadena de suministro [Ampliación actual]

Amenaza	Descripción	Defensas clave
Ransomware-as-a-Service (RaaS)	Modelo criminal en el que operadores proporcionan infraestructura y malware a afiliados.	Segmentación, copias de seguridad resistentes, EDR, MFA, gestión de privilegios, respuesta rápida.

Amenaza	Descripción	Defensas clave
Infostealers	Malware especializado en robar credenciales, cookies, tokens y datos del navegador.	EDR, control de aplicaciones, protección de navegador, MFA resistente al phishing, revocación de sesiones.
Credential stuffing	Uso automatizado de pares usuario/contraseña filtrados en otros servicios.	Contraseñas únicas, MFA, detección de abuso, limitación y protección de autenticación.
MFA fatigue / push bombing	Envío repetido de solicitudes MFA para inducir al usuario a aprobar una no legítima.	Métodos resistentes al phishing, number matching, alertas y procedimientos de rechazo/escalado.
Supply-chain attack	Compromiso de proveedor, dependencia, repositorio, actualización o canal de distribución.	SBOM, firma/verificación, control de dependencias, mínimos privilegios de CI/CD y monitorización.

La característica común es que el atacante intenta aprovechar relaciones de confianza: contraseñas reutilizadas, aprobaciones MFA, paquetes confiables, proveedores o canales de actualización. Esto exige controles que validen la identidad, la procedencia y el comportamiento, no solo el perímetro de red.

1.E OSINT y reconocimiento básico de superficie de ataque [Ampliación actual]

OSINT (Open Source Intelligence) es la obtención y análisis de información disponible públicamente. En ciberseguridad puede utilizarse defensivamente para conocer qué información de una organización está expuesta y qué podría aprovechar un adversario durante el reconocimiento.

Fuente/área	Riesgo defensivo a revisar
Dominios y subdominios	Inventario de presencia pública y servicios publicados.
Metadatos y documentos públicos	Tecnologías, nombres de usuario, estructura interna o información no necesaria.
Repositorios públicos	Código, documentación, configuraciones o secretos publicados por error.
Redes sociales y páginas corporativas	Roles, proveedores, tecnologías, eventos y datos útiles para ingeniería social.
Servicios expuestos	Puertos, paneles, APIs, sistemas de desarrollo o versiones accesibles públicamente.

Límite. Reconocimiento defensivo no equivale a acceso no autorizado. Debe respetarse el alcance, la legalidad, la privacidad y las condiciones de los servicios consultados.

1.F Seguridad de APIs y servicios web [Ampliación actual]

Las APIs exponen lógica y datos de aplicaciones de forma estructurada. Su seguridad depende especialmente de la autenticación, la autorización a nivel de objeto y función, la validación de entradas, el inventario de endpoints y el control del consumo de recursos.

Área	Buena práctica
------	----------------

Área	Buena práctica
Autorización por objeto	Comprobar que el usuario puede acceder a cada objeto solicitado, no solo que está autenticado.
Autenticación	Proteger credenciales, tokens, sesiones y mecanismos de recuperación.
Exposición de propiedades	Evitar devolver o modificar campos que el usuario no debe consultar o controlar.
Consumo de recursos	Aplicar límites, cuotas y validaciones para evitar abuso o agotamiento.
SSRF	Controlar destinos y parámetros cuando el servidor realiza peticiones a recursos externos.
Inventario	Conocer versiones y endpoints desplegados; retirar interfaces antiguas o de depuración.
APIs de terceros	No confiar automáticamente en los datos o controles del proveedor externo.

OWASP mantiene un Top 10 específico para APIs; su edición vigente sigue siendo la de 2023. Para alumnado de DAW/DAM es una referencia especialmente útil porque traduce los principios generales de seguridad a arquitecturas modernas basadas en servicios.

1.G Dependencias, paquetes, SBOM y software supply chain [Ampliación actual]

Las aplicaciones modernas incorporan una gran cantidad de bibliotecas, paquetes y servicios de terceros. Una vulnerabilidad puede estar en una dependencia directa, en una dependencia transitiva o en el propio proceso de construcción y distribución.

Una SBOM (Software Bill of Materials) es un inventario formal y legible por máquinas de los componentes de software y sus relaciones. Su valor principal es aportar transparencia: permite saber qué componentes y versiones forman parte de un producto y facilita responder con rapidez cuando se publica una vulnerabilidad relevante.

Objetivo	Aplicación
Inventariar	Conocer componentes, versiones y dependencias.
Correlacionar	Relacionar componentes con vulnerabilidades y avisos.
Priorizar	Detectar qué productos realmente contienen un componente afectado.
Actualizar	Gestionar versiones, sustituciones y componentes sin soporte.
Demostrar trazabilidad	Aportar información sobre procedencia y composición del software.

Controles complementarios: bloqueo de versiones mediante lockfiles, repositorios confiables, revisión de dependencias, actualización periódica, firma y verificación de artefactos, protección de credenciales de CI/CD y revisión de cambios en mantenedores o paquetes.

1.H Uso de IA en ataques y en detección y análisis de amenazas [Ampliación actual]

La inteligencia artificial amplía capacidades existentes tanto de atacantes como de defensores. No crea por sí sola una nueva categoría de ataque, pero reduce costes, acelera tareas y mejora la escala de determinadas operaciones.

Uso	Riesgo/capacidad ofensiva	Aplicación defensiva
Ingeniería social	Generación rápida de mensajes más naturales, traducción y personalización de señuelos.	Clasificadores, análisis contextual, formación, verificación de identidad y procesos fuera de banda.
Suplantación	Contenido sintético de voz, imagen o vídeo para reforzar un engaño.	Procedimientos de verificación y autenticación que no dependan solo de apariencia o voz.
Análisis de información	Resumen de grandes volúmenes de datos públicos o robados.	Controles de acceso, minimización de datos y protección de información expuesta.
Detección	Agrupación de alertas, priorización, detección de anomalías y asistencia al analista.	Validación humana, métricas de calidad, protección de datos y control de alucinaciones.
Automatización	Aceleración de tareas repetitivas de análisis o respuesta.	Guardrails, aprobación humana para acciones críticas, registros y reversibilidad.

Criterio profesional. Una salida generada por IA no es evidencia. Las conclusiones de seguridad deben contrastarse con logs, telemetría, configuraciones, inteligencia de amenazas y otras fuentes verificables.

3. Caso integrado de análisis

Una pequeña empresa publica una aplicación web de gestión. El servidor utiliza una biblioteca antigua con una vulnerabilidad conocida. Un empleado recibe un correo personalizado que aparenta proceder del proveedor de hosting y accede a una página falsa donde introduce sus credenciales. Horas después se detectan accesos desde una ubicación no habitual, descargas masivas y conexiones salientes periódicas desde el servidor.

Análisis guiado

Elemento	Interpretación
Activos	Credenciales del empleado, aplicación web, datos gestionados, servidor y continuidad del servicio.
Amenazas	Phishing dirigido, robo de credenciales, explotación de software vulnerable y posible malware/infostealer.
Vulnerabilidades	Factores humanos/procedimentales, autenticación insuficiente, componente desactualizado y posibles controles de monitorización débiles.
Señales	Ubicación de acceso inusual, descargas masivas y tráfico saliente periódico.
CIA	Confidencialidad: extracción de datos; integridad: posible modificación; disponibilidad: riesgo de cifrado o interrupción.
Clasificación	Ataque externo y dirigido; puede evolucionar a incidente de mayor alcance.
TTP	Reconocimiento/Initial Access/Credential Access/Collection/Exfiltration, según evidencias disponibles.
Acciones defensivas iniciales	Contener accesos, revocar sesiones/credenciales, conservar evidencias, revisar logs y activos afectados, actualizar componente y reforzar autenticación.

El caso muestra que un incidente real puede combinar varias debilidades. La causa no debe resumirse en “phishing” o “software vulnerable”: es necesario reconstruir la cadena y determinar qué controles fallaron o no existían.

4. Resumen de la unidad

Concepto	Clave para recordar
Amenaza	Capacidad potencial de causar daño.
Vulnerabilidad	Debilidad aprovechable.
Riesgo	Probabilidad e impacto contextualizados.
Ataque	Acción que intenta comprometer un activo.
CIA	Confidencialidad, integridad y disponibilidad.
Malware	Software malicioso con múltiples finalidades y vectores.
Ingeniería social	Manipulación de personas y procesos.
DoS/DDoS	Ataques contra la disponibilidad.
MitM	Interposición en una comunicación.
Exploit	Mecanismo para aprovechar una vulnerabilidad.

Concepto	Clave para recordar
SQLi/XSS	Ejemplos de vulnerabilidades/ataques de aplicaciones web.
IoC / señales	Evidencias que ayudan a detectar actividad sospechosa.
MITRE ATT&CK	Lenguaje para describir comportamientos del adversario.
CVE/CVSS	Identificación y valoración estandarizada de vulnerabilidades.
OWASP	Referencias para riesgos de aplicaciones y APIs.
SBOM	Inventario de componentes y dependencias de software.

Glosario esencial

Término	Definición
Activo	Elemento con valor que requiere protección.
Superficie de ataque	Conjunto de puntos por los que un actor podría interactuar con un sistema.
Vector de ataque	Ruta o medio utilizado para intentar alcanzar un activo.
TTP	Tácticas, técnicas y procedimientos observados en la actuación de adversarios.
CVE	Identificador público de una vulnerabilidad concreta.
CVSS	Sistema común para expresar características y severidad de vulnerabilidades.
CWE	Catálogo de tipos de debilidades de software.
IoC	Indicador de compromiso: dato observable asociado a actividad potencialmente maliciosa.
EDR	Tecnología de detección y respuesta en endpoints.
SBOM	Inventario estructurado de componentes de software.
API	Interfaz que permite la comunicación entre sistemas o componentes.
OSINT	Información obtenida de fuentes abiertas y públicamente disponibles.

5. Actividades propuestas

Actividad	Producto esperado	CE
Actividad 1. Clasificación de amenazas	A partir de 12 escenarios breves, identificar amenaza, activo, vulnerabilidad, vector e impacto CIA. Justificar la clasificación interno/externo y dirigido/masivo.	CE1-a, CE1-d, CE1-e
Actividad 2. Inventario de vulnerabilidades	Analizar un pequeño inventario de sistemas y aplicaciones, detectar debilidades y priorizarlas usando criticidad, exposición y CVSS como referencia.	CE1-b
Actividad 3. Cadena de ataque	Construir una cadena amenaza → vulnerabilidad → explotación → consecuencias → controles para un caso proporcionado por el profesor.	CE1-c
Actividad 4. Análisis de logs	Revisar registros simplificados de autenticación, web y red, identificar señales relevantes y separar falsos positivos razonables.	CE1-f

Actividad	Producto esperado	CE
Actividad 5. OWASP y API	Relacionar varios defectos de aplicaciones con categorías OWASP Top 10:2025 y OWASP API Security Top 10. Proponer medidas defensivas.	CE1-b, CE1-c
Actividad 6. Ficha técnica de amenaza	Elaborar una ficha de una amenaza actual: descripción, vector, activos, CIA, TTP, señales y medidas preventivas.	CE1-a, CE1-c, CE1-f

6. Trazabilidad de evaluación de la UD1

La siguiente tabla reproduce los indicadores de logro y ponderaciones del RA1 definidos en el Excel de planificación del módulo. La ponderación total del RA1 es 100 %. Los contenidos de la UD1 se integran además en la UD6 mediante actividades de análisis y documentación.

CE	Indicador	Peso %	Descripción	Contenidos vinculados
CE1-a	CE1-a-1	1,4	Identificar las principales amenazas informáticas y reconocer ejemplos representativos.	1.4, 1.5, 1.6
CE1-a	CE1-a-2	1,4	Explicar las características, funciones y formas de actuación de malware, phishing, ransomware y ataques DoS/DDoS.	1.4, 1.5, 1.6, 1.D
CE1-a	CE1-a-3	2,9	Clasificar amenazas informáticas a partir de descripciones y escenarios concretos.	1.4, 1.5, 1.6, 1.14
CE1-a	CE1-a-4	3,7	Analizar el funcionamiento y el vector de entrada de una amenaza en un caso práctico.	1.4, 1.6, 1.D
CE1-a	CE1-a-5	3,7	Comparar distintas amenazas atendiendo a su objetivo, alcance y modo de actuación.	1.4, 1.5, 1.6, 1.D
CE1-a	CE1-a-6	3,6	Elaborar una ficha técnica de amenazas que recoja características, funcionamiento y medidas preventivas básicas.	1.4, 1.5, 1.6, 6.13
CE1-b	CE1-b-1	1,4	Definir el concepto de vulnerabilidad y diferenciarlo de amenaza y riesgo.	1.1, 1.7, 1.8
CE1-b	CE1-b-2	1,4	Identificar vulnerabilidades frecuentes en sistemas operativos, redes, aplicaciones y redes inalámbricas.	1.7, 1.8
CE1-b	CE1-b-3	2,9	Clasificar vulnerabilidades técnicas a partir de casos y evidencias sencillas.	1.7, 1.8, 1.B
CE1-b	CE1-b-4	3,7	Analizar el impacto potencial de una vulnerabilidad sobre un sistema, red o aplicación.	1.7, 1.8, 1.12
CE1-b	CE1-b-5	3,7	Priorizar vulnerabilidades según criticidad, exposición e impacto utilizando criterios de riesgo.	1.B, 1.7, 1.12
CE1-b	CE1-b-6	3,6	Documentar un inventario básico de vulnerabilidades con su clasificación, impacto y prioridad de tratamiento.	1.B, 6.1, 6.13
CE1-c	CE1-c-1	1,4	Definir los conceptos de exploit, superficie de ataque y mecanismo de explotación.	1.9, 1.11
CE1-c	CE1-c-2	1,4	Explicar la relación entre amenaza, vulnerabilidad, exploit y ataque.	1.9, 1.11
CE1-c	CE1-c-3	2,9	Relacionar amenazas concretas con las vulnerabilidades que pueden explotar.	1.7, 1.9, 1.11
CE1-c	CE1-c-4	3,7	Analizar una cadena de ataque identificando vulnerabilidades, técnicas y mecanismos de explotación.	1.9, 1.10, 1.11, 1.A
CE1-c	CE1-c-5	3,7	Evaluar qué técnicas de ataque son más probables en función de la superficie expuesta y el contexto.	1.A, 1.E, 1.11
CE1-c	CE1-c-6	3,6	Documentar un escenario de ataque indicando amenaza, vulnerabilidad, mecanismo de explotación y posibles controles.	1.11, 6.1, 6.13
CE1-d	CE1-d-1	1,4	Definir los principios de confidencialidad, integridad y disponibilidad de la información.	1.2
CE1-d	CE1-d-2	1,4	Explicar cómo una amenaza puede afectar a cada dimensión de la tríada CIA.	1.2, 1.12
CE1-d	CE1-d-3	2,9	Determinar qué principios de seguridad resultan afectados en diferentes casos de ataque.	1.2, 1.12
CE1-d	CE1-d-4	3,7	Analizar las consecuencias técnicas y operativas de un incidente sobre datos y servicios.	1.12, 6.1
CE1-d	CE1-d-5	3,7	Evaluar la gravedad del impacto considerando confidencialidad, integridad, disponibilidad y continuidad del servicio.	1.12, 1.B, 6.12

CE	Indicador	Peso %	Descripción	Contenidos vinculados
CE1-d	CE1-d-6	3,6	Elaborar un informe breve de impacto que priorice los efectos y las necesidades de mitigación.	1.12, 6.13, 6.14
CE1-e	CE1-e-1	1,4	Identificar las categorías de ataques internos, externos, dirigidos y masivos.	1.14
CE1-e	CE1-e-2	1,4	Explicar las diferencias entre categorías atendiendo al origen, alcance y objetivo del atacante.	1.14
CE1-e	CE1-e-3	2,9	Clasificar casos de ataque según su categoría y justificar la decisión.	1.14, 3.2
CE1-e	CE1-e-4	3,7	Analizar el contexto, los activos objetivo y la motivación probable en diferentes escenarios.	1.14, 1.A
CE1-e	CE1-e-5	3,6	Evaluar situaciones ambiguas en las que un incidente pueda encajar en más de una categoría.	1.14, 1.A, 3.2
CE1-e	CE1-e-6	3,6	Documentar una clasificación razonada de incidentes según origen, alcance y objetivo.	1.14, 6.13
CE1-f	CE1-f-1	1,4	Reconocer señales básicas de actividad maliciosa en sistemas y redes.	1.13
CE1-f	CE1-f-2	1,4	Explicar la relación entre síntomas observables, registros y posibles amenazas activas.	1.13, 2.13
CE1-f	CE1-f-3	2,9	Identificar indicadores de actividad sospechosa en ejemplos de logs, procesos o tráfico de red.	1.13, 3.5, 3.6
CE1-f	CE1-f-4	3,7	Analizar un conjunto de evidencias para determinar si existe una posible amenaza o vulnerabilidad activa.	1.13, 3.5, 3.6, 3.H
CE1-f	CE1-f-5	3,6	Evaluar la relevancia de señales e indicadores descartando falsos positivos sencillos.	1.13, 3.5, 3.E
CE1-f	CE1-f-6	3,6	Documentar las evidencias detectadas y proponer las comprobaciones iniciales que deberían realizarse.	1.13, 6.9, 6.13

7. Fuentes y referencias

Fuentes curriculares y de planificación:

- CL2003 – Fundamentos de ciberseguridad (GS). Currículo aportado para el módulo: 54 horas, 2.º curso; RA1 y contenidos de amenazas y vulnerabilidades.
- CL2003_RAS_COMPLETO_CORREGIDO_CE.xlsx. Matriz de resultados de aprendizaje, criterios de evaluación, indicadores de logro, ponderaciones y trazabilidad de contenidos.

Referencias técnicas para las ampliaciones actuales (consultadas en septiembre de 2026):

- MITRE ATT&CK – Enterprise Matrix y versión 19.2 – <https://attack.mitre.org/matrices/enterprise/>
- MITRE ATT&CK – Updates (v19.2, agosto de 2026) – <https://attack.mitre.org/resources/updates/>
- FIRST – CVSS v4.0 Specification – <https://www.first.org/cvss/v4.0/specification-document>
- OWASP Top 10:2025 – <https://owasp.org/Top10/2025/>
- OWASP API Security Top 10:2023 – <https://owasp.org/API-Security/editions/2023/en/0x11-t10/>
- CISA – SBOM Resources Library – <https://www.cisa.gov/topics/cyber-threats-and-advisories/sbom/sbomresourceslibrary>

Nota de actualización. Los contenidos marcados como “Ampliación actual” evolucionan con rapidez. Conviene revisar las versiones vigentes de MITRE ATT&CK, OWASP, CVSS y guías de cadena de suministro al inicio de cada curso escolar.